

高安全属性价值设备威胁态势量化评估方法研究

基于《高安全属性价值设备威胁态势量化评估方法》的综述与分析

作者：张晗洁

网络态势评估从全网宏观视角下沉到关键设备微观视角

研究动机：宏观态势难以解释关键设备风险

传统问题

全网态势能反映总体趋势，但容易掩盖边界防火墙、核心服务、工业控制器等关键节点的局部高危状态。

高价值设备

这类设备对保密性、完整性、可用性影响显著，一旦失陷可能等价于关键业务域被攻破。

论文贡献

定义高安全属性价值设备，构建指标体系，并提出设备级威胁态势量化方法。

核心概念：安全属性价值决定评估优先级

设备安全属性价值由保密性、完整性、可用性及权重共同决定。

当 $\text{attrvalue} \geq \varepsilon$ 时，设备被识别为高安全属性价值设备。

原文实验中 FW IPSec 与 NFS 的属性价值超过阈值，是重点评估对象。

关键思想：同一攻击作用到不同设备，造成的业务后果不同。

评估框架：从属性采集到 ETSA 量化



输入：配置、脆弱性、性能、警报、安全属性价值。

过程：筛选有效警报，聚合状态，叠加性能劣化。

输出：设备威胁态势分数和可解释状态标签。

警报有效性：减少噪声，保留真正作用于设备的威胁

配置匹配

告警是否命中设备实际开放 IP、端口、服务和策略。

脆弱性匹配

告警是否与设备漏洞、异常类型、CVSS 分值或安全属性相关。

性能关联

告警高峰是否与 CPU、内存、带宽、会话、丢包等劣化一致。

实验平均警报约减率约 33.04%，体现了属性关联对告警噪声的压缩作用。

状态评估：从正常到扫描、威胁与拒服

有效警报被聚合为设备状态，攻击模式决定状态父子关系

。pthreat 区间用于界定正常、扫描、威胁、威胁&拒服和达成目标。

状态标签比单一分数更利于安全人员解释攻击阶段。

性能劣化：拒绝服务攻击的重要证据

CPU、内存：反映计算消耗型拒绝服务。
带宽、会话、丢包：反映带宽消耗型拒绝服务。
温度：反映运行环境对设备性能的综合影响。
性能曲线与有效警报分值同步升高时，威胁解释力更强。

ETSA：状态概率、状态损失与性能修正的综合分数

状态概率

由有效警报聚合得到，表示设备处于某安全状态的可能性。

状态损失

由设备安全属性价值和脆弱性严重程度共同决定。

性能修正

当性能劣化出现时， $\pi \times$ 性能变化累积量进入 ETSA。

实验验证：三个场景检验方法有效性

场景1：FW IPSec 暴露在互联网访问流量下。

场景2：互联网侧对 FW IPSec 进行扫描与拒绝服务模拟攻击。

场景3：内网侧对 NFS 进行扫描、提权尝试和拒绝服务攻击。

结果：有效警报分值、性能劣化、设备状态与模拟攻击行为相互对应。

方法对比：微观、通用、客观、可聚合

面向设备而非全网，针对性更强。
抽象出安全属性价值，较路由器专项指标更通用。
较少依赖专家赋值，更多基于概率和观测数据。
同时支持警报约减和警报聚合。

科研绘图总览

结论与启示

原文方法把态势评估从宏观网络推进到关键设备层。
安全属性价值用于识别重点设备，避免平均化掩盖关键风险。
有效警报、状态评估和性能修正共同构成 ETSA 量化逻辑。
适合关键基础设施、政务专网、金融网络和数据中心运维场景。

谢谢观看

作者：张晗洁